



DISSECTING THE UBER SECURITY BREACH: ROOT CAUSE ANALYSIS AND MITIGATION STRATEGIES

Ujjwal Sharma

Cyber Security Architect, Production Technology, SLB

Samruddhi Mangesh Kalekar

Technical Business Analyst, SAP, SLB

ABSTRACT

On Thursday, September 15th, 2022, Uber, an American multinational ride-share company, confirmed reports of an organization-wide cybersecurity breach. This concerns how an (allegedly) 18-year-old attacker could hack the ridesharing giant's IT infrastructure, acquire access to user data, and access vulnerabilities reported to Uber's HackerOne account. It's important to note that a single technology solution could not have avoided this breach, nor was it that a single person, company, or provider was to blame.

Building on CyberArk Red Team and Labs 'analysis, let's delve deeper into the Uber hack, particularly the hard-coded credentials that were reportedly used to gain administrative access. This incident underscores the criticality of stacked defenses, showing how they can effectively collaborate to thwart related attacks. This should instill confidence in our ability to mitigate such breaches in the future, knowing that we have a robust system in place.

Keywords: Uber, Social Engineering, PAM, Hardcoded Credentials, Data Exfiltration

Cite this Article: Ujjwal Sharma and Samruddhi Mangesh Kalekar, Dissecting the Uber Security Breach: Root Cause Analysis and Mitigation Strategies, *International Journal of Computer Engineering and Technology (IJCTET)*, 15(4), 2024, pp. 715-720.

https://iaeme.com/MasterAdmin/Journal_uploads/IJCTET/VOLUME_15_ISSUE_4/IJCTET_15_04_062.pdf

1. INTRODUCTION

The attack on Uber presents a wealth of learning opportunities for cybersecurity professionals. While much of the analysis has focused on the human element, such as social engineering and multi-factor authentication fatigue, the real turning point for the attack occurred post-initial access. Uber's September 19 security update shed some light on the situation, naming Lapsus\$ as a potential attacker group of interest. The confirmation that the attacker "Tea Pot" was affiliated with the Lapsus\$ hacking group, known for breaching NVIDIA, Samsung, and Microsoft earlier this year, was a significant revelation. The attacker likely targeted an external contractor whose credentials were purchased on the dark web.

Figure 1: GitGuardian Statement

"There have been three reported breaches involving Uber in 2014, 2016, and now 2022. It appears that all three incidents critically involve hardcoded credentials (secrets) inside code and scripts"

Mackenzie Jackson – Security Advocate at GitGuardian

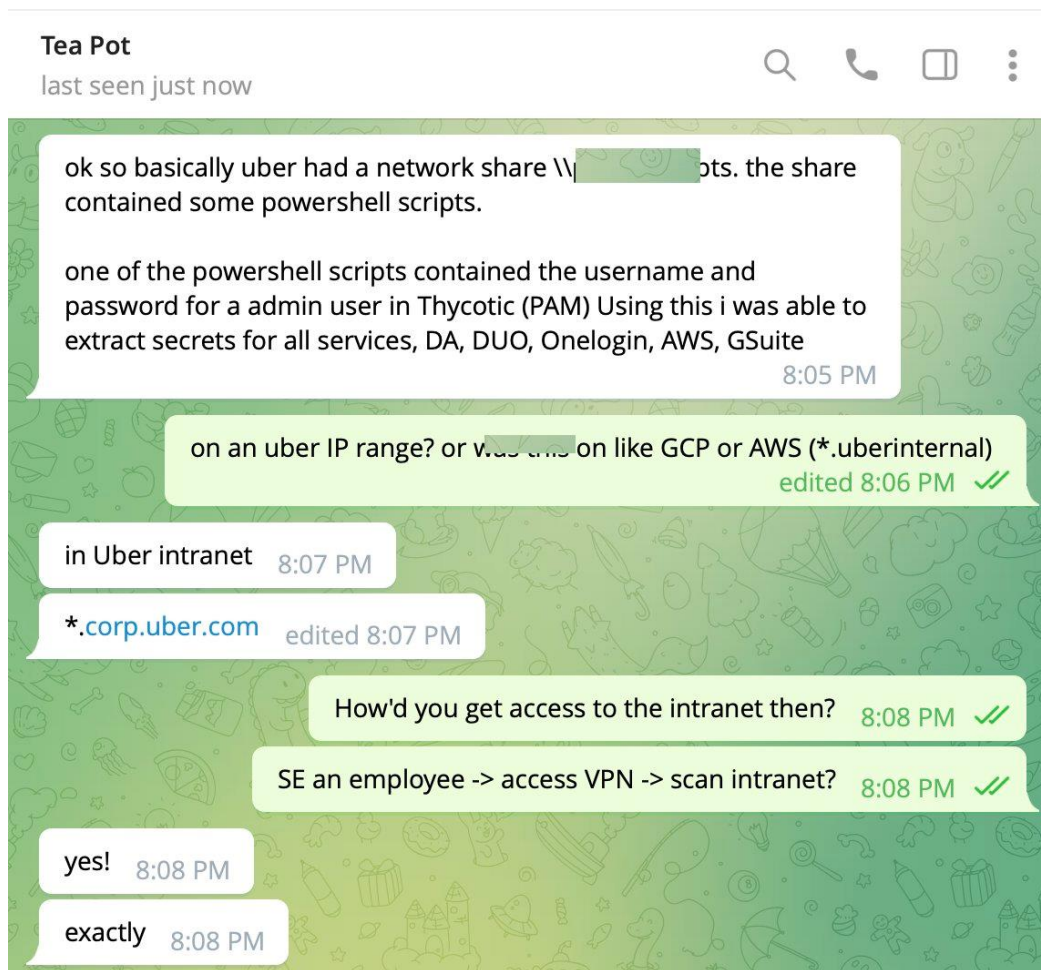
Figure 2: CyberArk Statement

"Much of the Uber cyber attack analysis has focused on social engineering and multiple MFA attack vectors, but the real turning point for the attack happened post initial access. The presence of embedded credentials, in a misconfigured network share is critical to deconstructing this attack. It was the harvesting credentials for a PAM solution embedded in PowerShell script that allowed the attacker to gain high-level access, escalate privileges and set off on a veritable field day inside Uber's IT environment. Proactive protection relies on implementing multiple security layers but most importantly, as this attack reinforces, the biggest takeaway is assume breach."

- Shay Nahari, Vice President, Red Team Services, CyberArk

Here's what we currently understand, pending further investigation and confirmation from Uber's security teams. The attack began with a social engineering campaign targeting Uber employees, resulting in access to a VPN and subsequently the internal network *.corp.uber.com. Once inside the network, the attacker discovered several PowerShell scripts, one containing hardcoded credentials for a domain admin account linked to Thycotic, Uber's Privileged Access Management (PAM) solution. With administrative privileges, the attacker gained control over various services and internal tools utilized by Uber, including AWS, GCP, Google Drive, Slack workspace, SentinelOne, HackerOne admin console, Uber's internal employee dashboards, and several code repositories.

Figure 3: Screenshot from a private message with the hacker on Telegram



2. ROOT CAUSE ANALYSIS

Let's deconstruct the entire attack to identify the incident's root cause.

Stage 1 – Initial access: The attacker gained access to Uber's VPN infrastructure credentials and entered its IT environment.

Stage 2 – Discovery: The contractor whose account was hacked probably did not have elevated or unique access rights to critical resources. However, they did have access to a network share, much like other Uber employees. Either this network share was accessible or misconfigured to allow a broad read of the Access Control List. The hacker then located a PowerShell script with hard-coded privileged credentials for Uber's Privileged Access Management (PAM) solution within the network share.

Side note: IT staff and developers frequently automate processes by writing scripts requiring authentication credentials (e.g., manual backup or generating custom reports by pulling data from databases). These credentials could be anything from privileged tokens and SSH keys to API tokens and other passwords. It's typical for developers to embed (or hard code) these credentials into the code to save time and assure automation. This makes it challenging to manage and rotate the credentials because they are left open to everyone with access to the code.

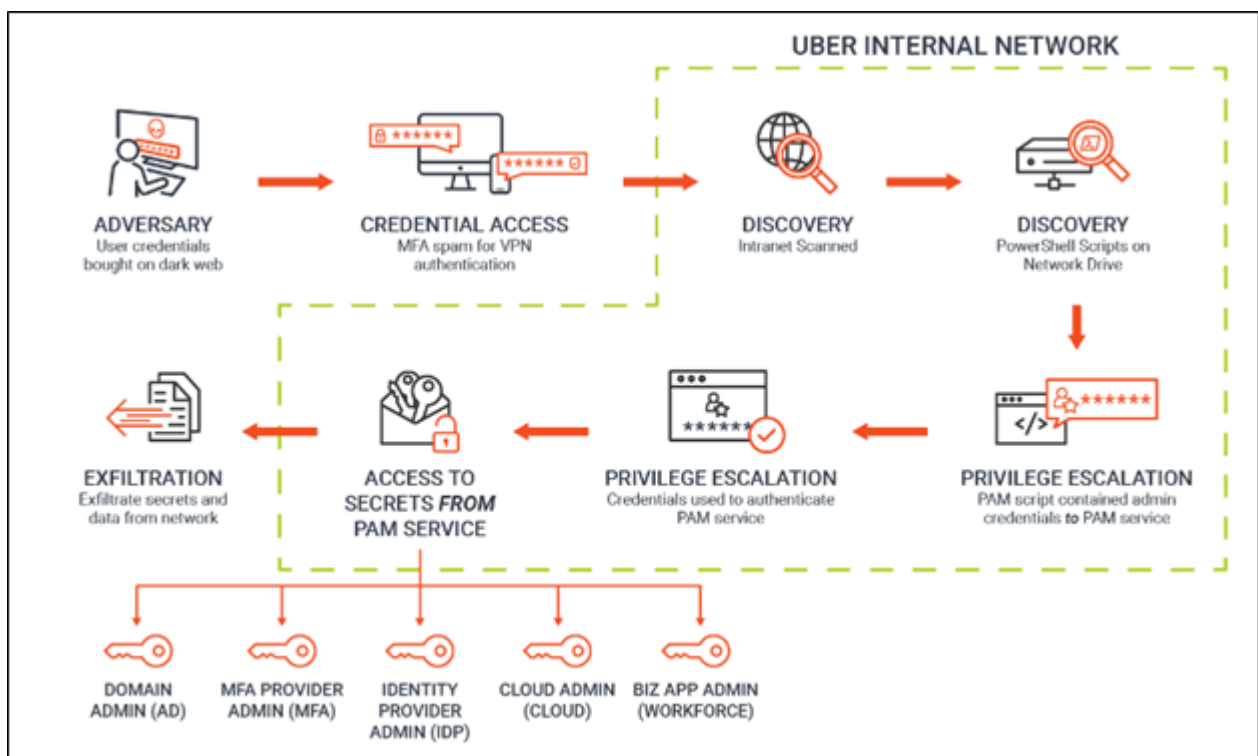
Hard-coded credentials used in the Uber breach allowed administrative access to a privileged access management program. These credentials looked to have not been rotated in a while, making them considerably simpler to exploit.

Stage 3 – Access PAM system and privilege escalation: The attacker further elevates privileges by stealing the privileged access management solution’s hard-coded admin credentials.

Stage 4 – Access PAM system secrets and critical company systems: The attacker ultimately obtained “elevated permissions to a number of tools,” according to an Uber update. Accessing privileged access management solution secrets had a high potential for harm. According to reports, the hacker gained access to the SSO, consoles, and cloud management console, which Uber uses to store confidential customer and financial information.

Stage 5 – Data exfiltration: Uber has confirmed that the attacker downloaded some internal Slack messages and accessed or downloaded information from an internal tool utilized by our finance team for managing specific invoices.

Figure 4: RCA of Uber Attack



3. RECOMMENDATIONS TO MITIGATE THE INCIDENT

Proactive protection requires a defense-in-depth strategy, combining complementary security layers supporting a zero-trust strategy that utilizes strong least-privilege controls. In this case, the first step to avoiding a similar attack would be to eliminate any embedded credentials. Will advise stopping this practice in addition to performing an environment inventory to identify and delete any hard-coded credentials that may be present in code, PaaS configurations, DevOps tools, and in-house developed applications.

This is easier said than done. Therefore, concentrate first on the organization's most vital and potent credentials and secrets before gradually extending these best practices to reduce risk.

Consider taking the following extra measures to strengthen the defenses after you've developed a strategy for dealing with hard-coded credentials:

- The most significant risk still stems from credential theft. As we've recently observed, attackers are becoming more adept at getting around MFA by utilizing a wide range of vectors and methods. The Uber story features multiple MFA compromises. Your staff members are your gatekeepers, so routinely teach them to recognize and report phishing to help avoid identity theft. As attacks continue to change, expect alertness but not absolute precision.
- Additionally, it's essential to ensure workers and outside contractors have the least permissions necessary to perform their responsibilities. Consistently apply the principle of least privilege, beginning at the endpoint. Set up privileged access management programs with the utmost care. Administrators should only be granted access to privileged accounts when absolutely necessary. All privileged account access needs to be separated and validated.
- This attack again highlighted the 'zero secrets' issue, with which security professionals have long struggled: What happens if someone manages to get hold of the key that safeguards all other keys? Strong defense-in-depth proactive and reactive controls are essential for this reason. They ensure other systems can detect and stop threats even if MFA is compromised.
- Limiting lateral movement can also be of enormous help. This can be done by removing standing access to sensitive infrastructure and online or cloud interfaces. Just-in-time elevation of privileges can significantly minimize the access of any compromised identity, reducing the blast radius of an attacker – especially when combined with robust authentication.

4. CONCLUSION

It's worth re-stating that there's no silver bullet solution to stopping cyber-attacks, and certainly not in Uber's case, just as the tools and people it has in place are not at fault. No one believes attacks can be flat-out stopped anymore. But we can be in control of how bad they become. Attacks such as the Uber breach can be mitigated by robust, layered cybersecurity defenses bolstered by constant and repeated staff education to help recognize potential sources of danger. These measures make it more difficult for attackers to gain a foothold, move, discover, and achieve their objectives. Just as importantly, they allow us to minimize the success and impact of attacks and get back to normal operations as quickly as possible. This is the meaningful learning we should take and apply to our organizations.

REFERENCES

- [1] Uber Newsroom Security update <https://www.uber.com/newsroom/security-update/>
- [2] Uber Users: What You Need to Know About Last Month's Data Breach <https://www.bu.edu/articles/2022/what-you-need-to-know-about-uber-data-breach/#:~:text=Last%20month%2C%20the%20internal%20databases,measures%20made%20the%20breach%20possible>
- [3] Uber Breach 2022 – Everything You Need to Know <https://blog.gitguardian.com/uber-breach-2022/>
- [4] Case Study: Critical Controls that Sony Should Have Implemented <https://sansorg.egnyte.com/dl/xZ10arL86x>
- [5] Sharma, U. and Kalekar, S.M., Most Prominent Pandemics of Cyber Viruses.
- [6] Most Prominent Pandemics of Cyber Viruses - Ujjwal Sharma, Samruddhi Mangesh Kalekar - IJFMR Volume 6, Issue 3, May-June 2024. DOI 10.36948/ijfmr.2024.v06i03.22089
- [7] CyberArk Blog Team (2022). *Unpacking the Uber Breach*. [online] www.cyberark.com. Available at: <https://www.cyberark.com/resources/blog/unpacking-the-uber-breach>
- [8] Golandaz, A. and Sharma, U., IoT Under Siege: The Dark Side of Internet Connected Devices.
- [9] IoT Under Siege: The Dark Side of Internet-Connected Devices - Aamerkhan Golandaz, Ujjwal Sharma - IJFMR Volume 6, Issue 3, May-June 2024. DOI 10.36948/ijfmr.2024.v06i03.22797

Citation: Ujjwal Sharma and Samruddhi Mangesh Kalekar, Dissecting the Uber Security Breach: Root Cause Analysis and Mitigation Strategies, International Journal of Computer Engineering and Technology (IJCET), 15(4), 2024, pp. 715-720

Abstract Link: https://iaeme.com/Home/article_id/IJCET_15_04_062

Article Link:

https://iaeme.com/MasterAdmin/Journal_uploads/IJCET/VOLUME_15_ISSUE_4/IJCET_15_04_062.pdf

Copyright: © 2024 Authors. This is an open-access article distributed under the terms of the Creative Commons Attribution License, which permits unrestricted use, distribution, and reproduction in any medium, provided the original author and source are credited.

This work is licensed under a **Creative Commons Attribution 4.0 International License (CC BY 4.0)**.



✉ editor@iaeme.com